

The background of the slide features a grayscale image of a silver ballpoint pen resting diagonally across a spreadsheet with a grid of cells. The pen is positioned from the upper left towards the lower right.

IT AUDITING IS4101

Mrs. Kumudu Wijerathna
Department of Computing and Information Systems,
Faculty of Computing

Lesson Learning Outcome

By the end of this lesson, you will be able to,

- Explain audit objectives related to network security
- Apply simple audit procedures for network controls

Content

Auditing Operating Systems and Networks

Network Security

Concern: Unauthorized access to confidential information

- Risks Without Protection:
 - Vulnerable to hackers, vandals, thieves, and spies
 - Threats from both inside and outside the organization
- Audit Categories:
 1. Intranet Risks: From dishonest employees
 2. Internet Risks: Affecting consumers and businesses

1. Intranet Risks

- Intranet Structure:
 - Small LANs and large WANs with thousands of nodes
- Usage - Connects employees within a building, across a campus, and between distant locations
- Common Activities:
 - Email routing
 - Transaction processing between business units
 - Linking to the Internet

1. Intranet Risks

Common Risks includes

- Interception of Network Messages
 - Interception, Modification, Fabrication
- Access to Corporate Databases
- Privileged Employees

2. Internet Risks

- Major Business Risks:

- i. IP Spoofing:

- Masquerading to gain unauthorized access or commit unlawful acts without revealing identity

- ii. Denial of Service (DoS) Attacks:

- Assault on a Web server to prevent service to legitimate users
 - Common types:

SYN flood

Smurf

Distributed Denial of Service (DDoS)

2. Internet Risks

iii. Equipment Failure:

- Network topology is created with different structures
 - Disruption in
 - communications lines – twisted pair wire, cable, fiber optics, etc.
 - hardware components – modems, servers, frontend processors, etc.
 - Software – protocol, network control system
- Can result in transmission issues and loss of databases and programs on servers

Controlling Networks

There are two major categories

1. Controlling Risks from Subversive Threats
2. Controlling Risks from Equipment Failure

1. Controlling Risks from Subversive Threats

Various control techniques employed to mitigate the risks

- Firewalls
- Controlling Denial of Service Attacks
- Encryption
- Digital Signatures
- Digital Certificate
- Message Sequence Numbering
- Message Transaction Log
- Call-Back Devices

Firewalls

- Purpose - Protects the intranet from outside intruders
- Function - Enforces access control between two networks

1. Traffic Control:

All traffic between the outside network and the intranet must pass through the firewall

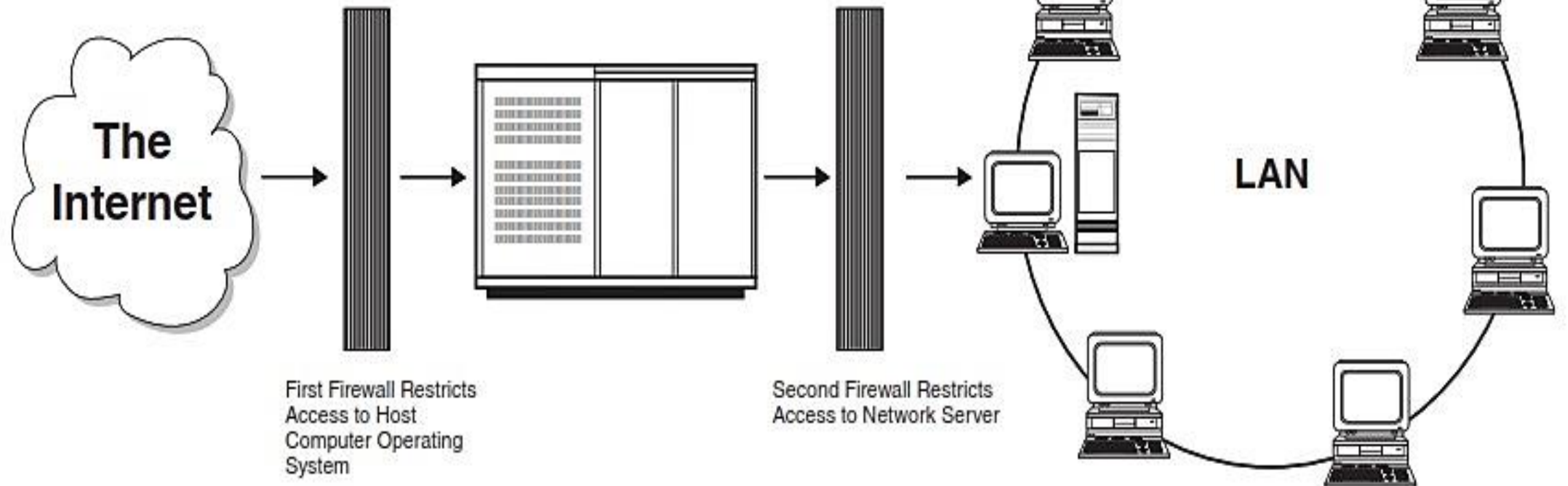
2. Authorization:

Only authorized traffic, as per security policy, is allowed through

3. Security:

Must be immune to penetration from both outside and inside the organization

Access Attempts from the Internet



Controlling Denial of Service (DoS) Attacks

- Smurf Attack Countermeasure:

Program the firewall to ignore all communication from the attacker's IP address

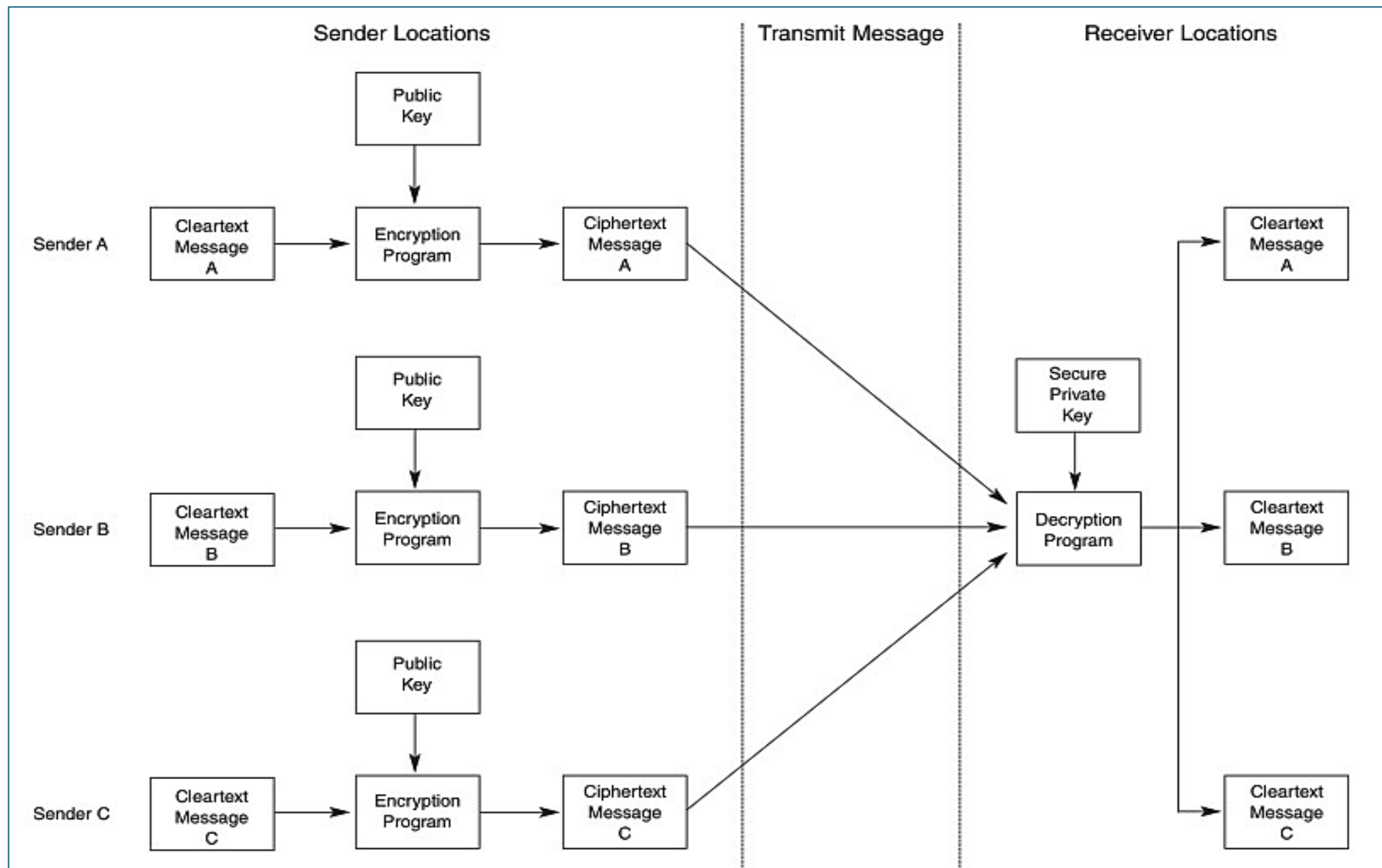
- DDoS Attack Countermeasure:

Invest in Intrusion Prevention Systems (IPS)

Encryption

Conversion of data into a secret code for storage and transmission

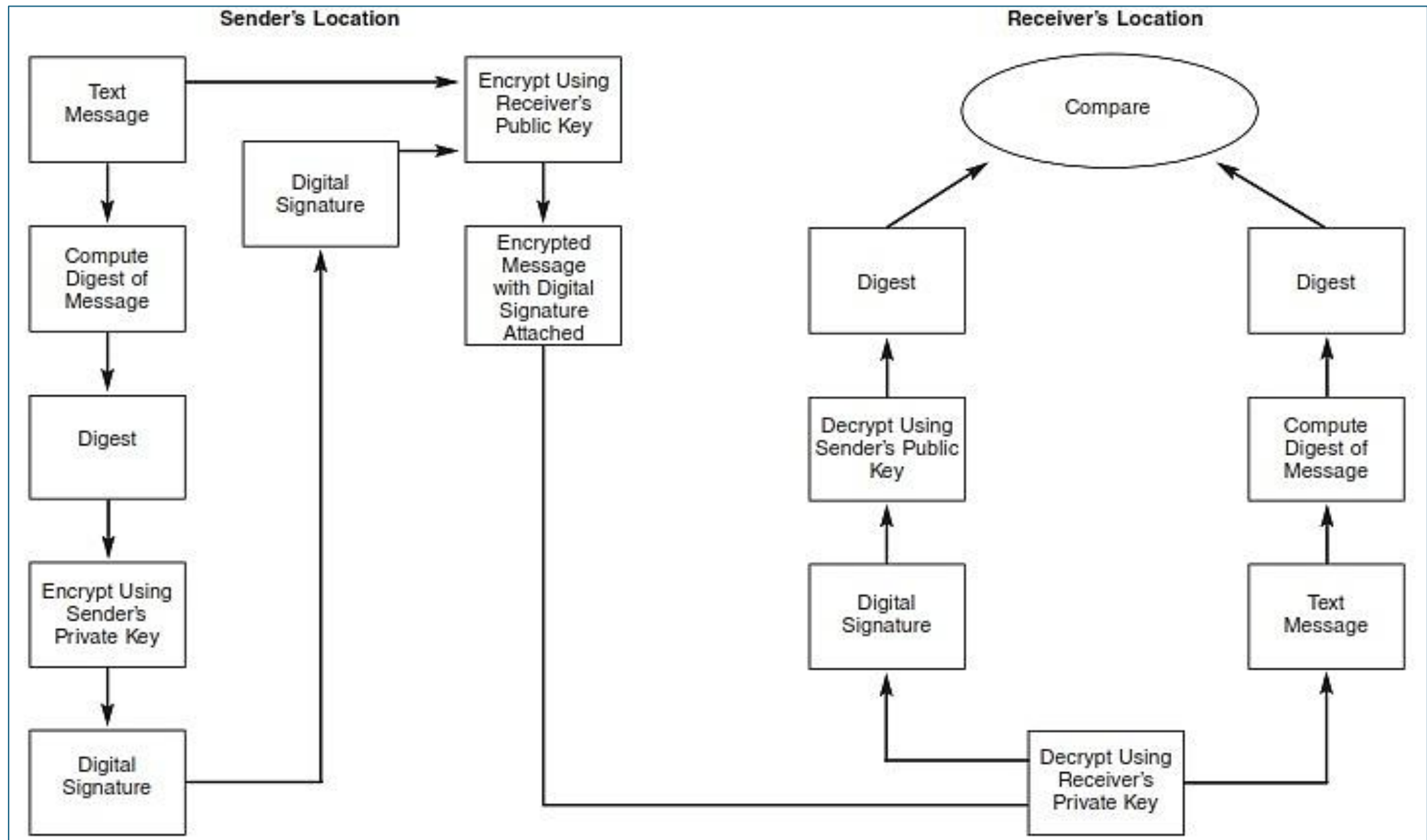
- Process:
 - Encryption - Sender converts the original message (clear text) into a coded version (cipher text)
 - Decryption - Receiver decodes the cipher text back into clear text
- Methods:
 - Private Key Encryption
 - Public Key Encryption



Digital Signatures

Electronic authentication that cannot be forged

- Ensures the message or document was not tampered with after the signature was applied



Audit Objectives for Subversive Threats

- Objective- Verify security and integrity of financial transactions
 - Prevent & Detect:
 - Network controls should prevent and detect illegal access both internally and from the Internet
 - Data Protection:
 - Make captured data useless to perpetrators
 - Integrity & Security:
 - Ensure network controls preserve data integrity and physical security

Audit Procedures for Subversive Threats

- Firewall Review:
 - Check adequacy in balancing control and convenience based on business objectives and risks
- Intrusion Prevention System (IPS):
 - Verify presence of IPS with Deep Packet Inspection (DPI) for vulnerable organizations (e.g., financial institutions)
- Data Encryption Key Security:
 - Review procedures for managing data encryption keys

Audit Procedures for Subversive Threats

- Encryption Process Verification:
 - Transmit a test message and examine contents at various points in the transmission channel
- Message Transaction Logs:
 - Ensure all messages are received in the correct sequence
- Callback Feature Test:
 - Test by placing an unauthorized call from outside the installation

2. Controlling Risks from Equipment Failure

- Line Errors:
 - Echo Check - Verify that the data sent matches the data received
 - Parity Check - Check for errors in data transmission by adding a parity bit
- Audit Objectives:
 - Assess how well the organization controls and prevents equipment failure
- Audit Procedures:
 - Review and test line error detection methods
 - Evaluate the effectiveness of error-checking mechanisms
 - (ex - Echo Check, Parity Check).

Summary

- Networks face threats from both internal and external users
- Security controls protect systems and confidential information
- Firewalls and encryption improve network security
- Auditors evaluate whether network controls are effective
- Proper monitoring helps detect and prevent attacks

Thank you